

Task 1 — Vulnerability Assessment of a Website

OWASP Juice Shop, tested locally

Intern	Prajwal
Internship	Indravex Technologies — Cyber Security Internship
Target	OWASP Juice Shop — http://localhost:3000 (local, self-hosted)
Date	11 August 2026

1. Objective

Find and document security issues in a web app using a standard vulnerability assessment workflow — from mapping the target, to checking the server, to testing the actual application logic. Everything here was run against a copy of OWASP Juice Shop hosted locally on my own machine, not a live or third-party site.

2. Tools Used

- Nmap — to see what's running and on which port
- Nikto — to check the web server for common misconfigurations
- OWASP ZAP — to test the actual application for exploitable flaws
- Docker — to run Juice Shop locally as an isolated, safe target

3. Methodology

I went broad to narrow: Nmap first to confirm what's actually reachable, Nikto next to check the web server itself, and ZAP last to dig into the application's own logic — forms, inputs, and how it handles what users type in. Each tool answers a different question, so running them in this order builds a fuller picture instead of duplicating effort.

4. Steps Performed

Set up the target:

- Ran Juice Shop locally in Docker: `docker run -d -p 3000:3000 docker.io/bkimminich/juice-shop`
- Confirmed it was up with `docker ps` and by loading `localhost:3000` in the browser

Reconnaissance with Nmap:

- `nmap -sV -sC -p- localhost -oN nmap_results.txt`
- Confirmed port 3000 open and identified the app from the raw HTTP response

Server scan with Nikto:

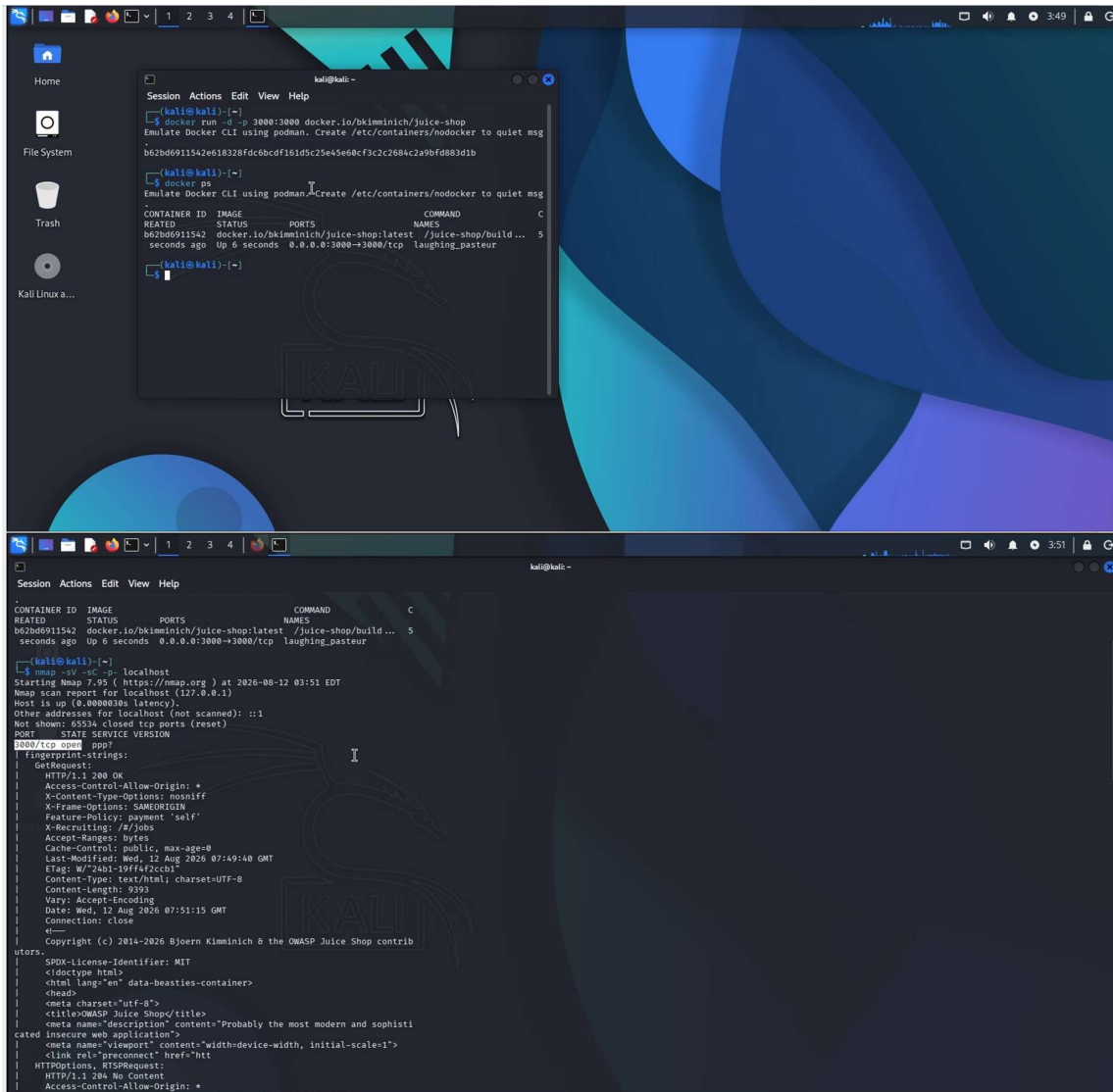
- `nikto -h http://localhost:3000 -o nikto_results.txt`
- Got a flood of "backup file found" results — verified with `curl` that these were false positives (the app returns 200 OK for any path since it's a single-page app, not proper 404s)

Application testing with ZAP:

- Ran ZAP's Automated Scan (Spider + Active Scan) against `localhost:3000`
- Reviewed each alert's raw request/response instead of trusting the alert title alone

- Excluded 4 alerts that turned out to be Firefox's own background telemetry, unrelated to Juice Shop

5. Screenshots



kali@kali -

Session Actions Edit View Help

```
-$ nikto -h http://localhost:3000
Nikto v2.5.0
```

Target IP: 127.0.0.1
Target Hostname: localhost
Target Port: 3000
Start Time: 2026-08-12 03:58:05 (GMT-4)

Server: No banner retrieved
/ Retrieved access-control-allow-origin header: *
/ Uncommon header 'x-recruiting' found, with contents: /#jobs.
/ No CGI Directories found (use "-C all" to force check all possible dirs)
/ Robots.txt: Entry /ftp/ is returned a non-forbidden or redirect HTTP code (200). See: https://portswigger.net/hq/issues/80600000_robots-txt-file
/ Robots.txt: contains 1 entry which should be manually viewed. See: https://developer.mozilla.org/en-US/docs/Glossary/Robots.txt
/ The X-Content-Type-Options header is not set. This could allow the user agent to render the content of the site in a different fashion to the MIME type. See: https://www.netsparker.com/web-vulnerability-scanner/vulnerabilities/missing-content-type-header/
/ localhost.pem: Potentially interesting backup/cert file found. See: https://cwe.mitre.org/data/definitions/530.html
/ site.tar.bz2: Potentially interesting backup/cert file found. See: https://cwe.mitre.org/data/definitions/530.html
/ localhost.tar: Potentially interesting backup/cert file found. See: https://cwe.mitre.org/data/definitions/530.html
/ dump.egg: Potentially interesting backup/cert file found. See: https://cwe.mitre.org/data/definitions/530.html
/ 127.0.0.1.tar: Potentially interesting backup/cert file found. See: https://cwe.mitre.org/data/definitions/530.html
/ 127.0.0.1.pem: Potentially interesting backup/cert file found. See: https://cwe.mitre.org/data/definitions/530.html
/ site.egg: Potentially interesting backup/cert file found. See: https://cwe.mitre.org/data/definitions/530.html
/ archive.pem: Potentially interesting backup/cert file found. See: https://cwe.mitre.org/data/definitions/530.html
/ backup.tar.lzma: Potentially interesting backup/cert file found. See: https://cwe.mitre.org/data/definitions/530.html
/ dump.tar.bz2: Potentially interesting backup/cert file found. See: https://cwe.mitre.org/data/definitions/530.html
/ localhost.tar.lzma: Potentially interesting backup/cert file found. See: https://cwe.mitre.org/data/definitions/530.html
/ database.cer: Potentially interesting backup/cert file found. See: https://cwe.mitre.org/data/definitions/530.html
/ site.tgz: Potentially interesting backup/cert file found. See: https://cwe.mitre.org/data/definitions/530.html
/ archive.egg: Potentially interesting backup/cert file found. See: https://cwe.mitre.org/data/definitions/530.html
/ localhost.js: Potentially interesting backup/cert file found. See: https://cwe.mitre.org/data/definitions/530.html
/ archive.tar.lzma: Potentially interesting backup/cert file found. See: https://cwe.mitre.org/data/definitions/530.html
/ backup.cer: Potentially interesting backup/cert file found. See: https://cwe.mitre.org/data/definitions/530.html
/ dump.pem: Potentially interesting backup/cert file found. See: https://cwe.mitre.org/data/definitions/530.html
/ site.tar.lzma: Potentially interesting backup/cert file found. See: https://cwe.mitre.org/data/definitions/530.html
/ 127.0.0.1.alz: Potentially interesting backup/cert file found. See: https://cwe.mitre.org/data/definitions/530.html
/ database.cer: Potentially interesting backup/cert file found. See: https://cwe.mitre.org/data/definitions/530.html
/ database.tar.bz2: Potentially interesting backup/cert file found. See: https://cwe.mitre.org/data/definitions/530.html
/ backup.tar.bz2: Potentially interesting backup/cert file found. See: https://cwe.mitre.org/data/definitions/530.html
/ database.war: Potentially interesting backup/cert file found. See: https://cwe.mitre.org/data/definitions/530.html
/ dump.tgz: Potentially interesting backup/cert file found. See: https://cwe.mitre.org/data/definitions/530.html
/ localhost.alz: Potentially interesting backup/cert file found. See: https://cwe.mitre.org/data/definitions/530.html
/ backup.pem: Potentially interesting backup/cert file found. See: https://cwe.mitre.org/data/definitions/530.html
/ 127.0.0.1.tar.lzma: Potentially interesting backup/cert file found. See: https://cwe.mitre.org/data/definitions/530.html
/ site.pem: Potentially interesting backup/cert file found. See: https://cwe.mitre.org/data/definitions/530.html
/ dump.tar.lzma: Potentially interesting backup/cert file found. See: https://cwe.mitre.org/data/definitions/530.html
/ 127.0.0.1.js: Potentially interesting backup/cert file found. See: https://cwe.mitre.org/data/definitions/530.html
/ database.alz: Potentially interesting backup/cert file found. See: https://cwe.mitre.org/data/definitions/530.html

1 host(s) tested

curl -i http://localhost:3000/archive.egg
curl: (7) Failed to connect to localhost port 3000 after 0 ms: Could not connect

zapproxy
found Java version 21.0.9
Available memory: 7909 MB
Using JVM args: -Xmx1977m
774 [main] INFO org.zaproxy.zap.GuiBootstrap - ZAP 2.17.0 started 12/08/2026, at 09:13:11
913 [AWT-EventQueue-0] WARN org.zaproxy.zap.GuiBootstrap - Failed to set awt keymap does not 'opens sun.awt.X11' to unnamed module 033c5b5951
1767 [AWT-EventQueue-0] INFO org.parosproxy.paros.view.View - Initialising View
3099 [ZAP-BootstrapGUI] INFO org.zaproxy.zap.control.ExtensionFactory - Install extensions: [id-bruteforce, version=20.0.0], [id-callhome, version=0.20.0], [id-list, version=0.0.0], [id-domains, version=23.0.0], [id-encoder, version=1.0.0], [id-graftjs, version=0.12.0], [id-graphql, version=0.29.0], [id-help, version=22.0.0], [id-onlineMenu, version=15.0.0], [id-openapi, version=48.0.0], [id-selenium, version=15.43.0], [id-sequence, version=9.0.0], [id-erlflux, version=169.0.0], [id-websocket, version=35.0.0], [id-test, version=48.0.0]
3183 [ZAP-BootstrapGUI] INFO org.zaproxy.zap.control.ExtensionFactory - Loading extensions
3672 [ZAP-BootstrapGUI] INFO org.zaproxy.zap.control.ExtensionFactory - Using supported SSL/TLS protocols: [TLSv1.2, TLSv1.3]
4061 [ZAP-BootstrapGUI] INFO org.zaproxy.zap.control.ExtensionFactory - Extensions loaded
5072 [ZAP-BootstrapGUI] INFO org.parosproxy.paros.extension.ExtensionLoader - Initializing Auto-update Extension - Allows ZAP to check for updates
5953 [ZAP-BootstrapGUI] INFO org.parosproxy.paros.extension.ExtensionLoader - Initializing Options Extension - Options Extension
6273 [ZAP-BootstrapGUI] INFO org.parosproxy.paros.extension.ExtensionLoader - Initializing Edit Menu Extension - Edit Menu Extension
6278 [ZAP-BootstrapGUI] INFO org.parosproxy.paros.extension.ExtensionLoader - Initializing API Extension - Provides a rest based API for controlling and accessing ZAP
6303 [ZAP-BootstrapGUI] INFO org.parosproxy.paros.extension.ExtensionLoader - Initializing History Extension - History Extension

ZAP by Checkmarx 2.17.0

ZAP Tips and Tricks:

Click on the 'gear' icon on the right hand side of many tabs to quickly access the setting for that feature. |

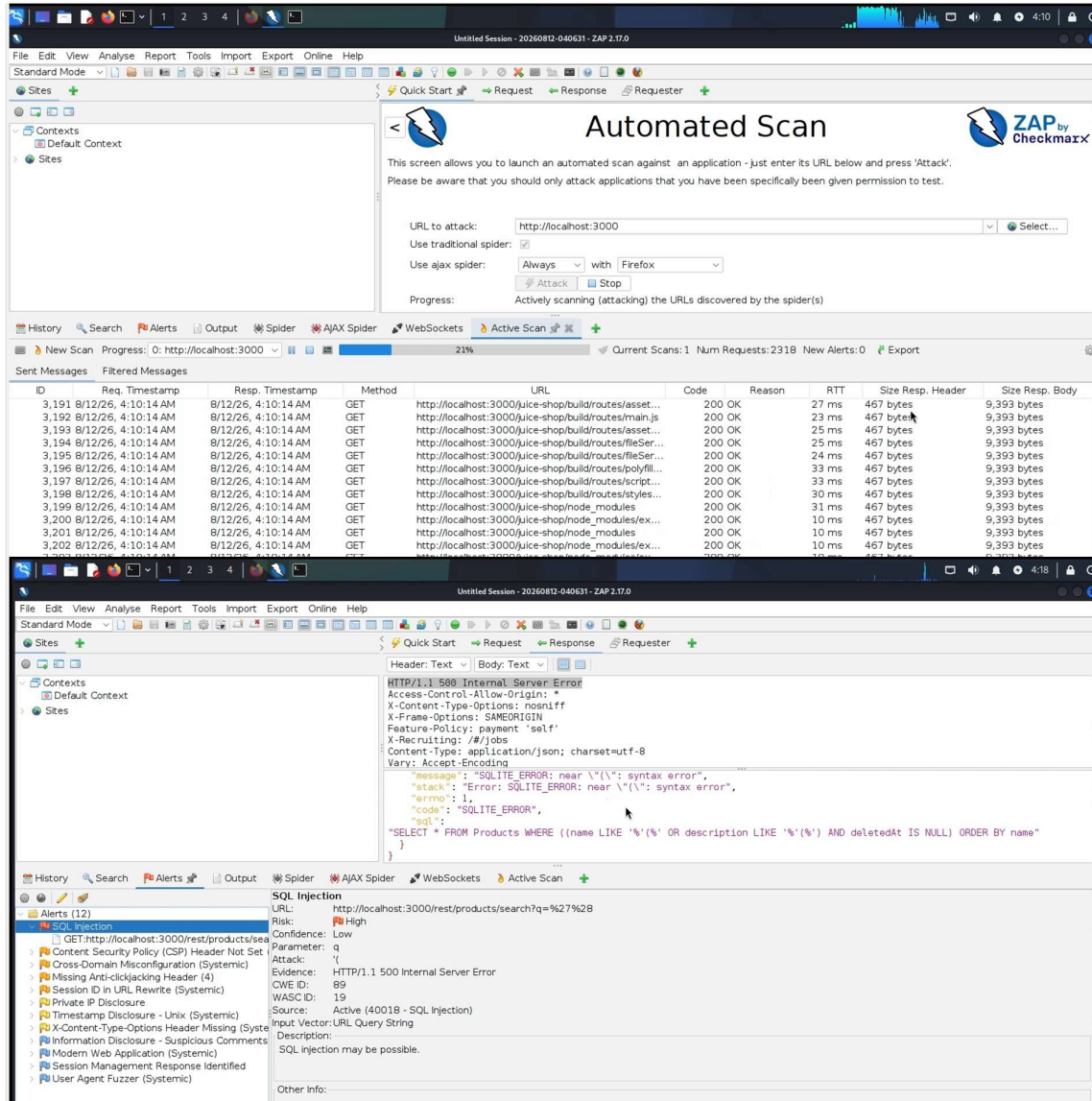
Intercept and modify requests and responses

INFO: Initializing Passive Scan Extension - Passive Scanner

INFO: Initializing Alerts Extension - Allows you to view

1 GB
lang.String sun.awt.X11.XToolkit.awtAppClassName accessible: module java.desktop

canrules, version=78.0.0], [id-authhelper, version=0.34.0], [id-automation, version=19.0.0], [id-database, version=0.9.0], [id-diff, version=18.0.0], [id-directory, version=5.0.0], [id-fuzz, version=13.16.0], [id-gettingStarted, version=20.0.0], [id-1], [id-invoke, version=17.0.0], [id-network, version=0.25.0], [id-oast, version=10.0.0], [id-quickstart, version=53.0.0], [id-replacer, version=0.0.0], [id-reveal, version=19.0.0], [id-scannolices, version=0.7.0], [id-script, version=0.0.0], [id-spiderAjax, version=23.29.0], [id-tips, version=16.0.0], [id-webdriv



6. Findings

Here's everything that came up, tool by tool:

Tool	Finding	Risk
Nmap	Port 3000 open, running Juice Shop (identified via page title in the raw response)	Low
Nikto	CORS wildcard header + unusual X-Recruiting header	Low
Nikto	Flood of "backup file found" hits — confirmed false positives via curl	—
ZAP	SQL Injection in the search box — confirmed via a real database error	High
ZAP	No Content-Security-Policy header	Medium
ZAP	Session ID passed in the URL instead of a cookie	Medium
ZAP	CORS wildcard (Access-Control-Allow-Origin: *)	Medium
ZAP	No clickjacking protection (X-Frame-Options missing)	Medium

A handful of smaller things also came up — a couple of internal IPs and a timestamp showing up in a response, plus a leftover developer comment in the JS. Nothing urgent, just worth a mention rather than a full write-up each.

7. Risk Analysis

The SQL Injection is the one that actually matters — it's a High risk because, if someone pushed further than just triggering an error, they could pull data out of the database they were never meant to see, or bypass login entirely. That's the difference between a scan finding and a real breach.

The Medium items (missing headers, CORS wildcard, session ID in the URL) aren't exploitable on their own the same way, but they're the kind of thing that makes a real attack easier once something else goes wrong — they're removing safety nets rather than causing damage directly.

Everything else is low-impact on a local test app like this, but would still be worth fixing in a real deployment since small leaks add up over time.

8. Recommendations

- Fix the SQL Injection first — use parameterized queries instead of building SQL from raw input, and don't return raw DB errors to the client
- Add the missing headers: Content-Security-Policy and X-Frame-Options
- Replace the CORS wildcard with a specific list of trusted origins
- Move the session ID into an HttpOnly cookie, out of the URL
- Clean up leftover internal IPs, timestamps, and dev comments before shipping to production

9. Conclusion

This task walked through a full assessment — from finding what's running, to checking the server, to actually testing the application logic. The SQL Injection was the standout finding and the clearest example of why input validation matters. Just as useful was catching Nikto's false positives instead of taking the raw output at face value — that's really the core skill this task was testing, not just running tools.